

Cybersecurity Daily Newsletter

Vol. 005 | 2026-09-12 09:00 WIB

Top 5 Highlights

- Why AI raises the stakes for exposure validation
- Max severity GitLab path traversal flaw under active reconnaissance
- 9/11 at 25, OfferLoader, Gemini CLI, Liquid, 10% Doom, Josh Marpet, and More - SWN #615
- VU#369611: ExLlamaV3 contains Denial of Service vulnerability via insufficient bounds checking on kernel dispatch index
- Threat Actor Generates 1M Personalized Fraud Emails in 3 Days

Threat Intelligence (10)

01. 9/11 at 25, OfferLoader, Gemini CLI, Liquid, 10% Doom, Josh Marpet, and More - SWN #615

9/11 at 25, OfferLoader, Gemini CLI, Liquid, 10% Doom, Josh Marpet, and More - SWN #615

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.scworld.com/podcast-segment/15298-9-11-at-25-offerloader-gemini-cli-liquid-10-doom-josh-marpet-and-more-swn-615>

02. Artifactory flaws chained in attacks deploying backdoor malware

Threat actors are exploiting critical and high-severity vulnerabilities in JFrog Artifactory to bypass authentication, gain administrative privileges, and deploy a Rust backdoor on vulnerable self-hosted servers. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.bleepingcomputer.com/news/security/artifactory-flaws-chained-in-attacks-deploying-backdoor-malware/>

03. In Other News: InjectEave Attack, SIM Swapper Sentenced, Glasswing Findings Review

Noteworthy stories that might have slipped under the radar: Invisible Unicode slips past phishing filters, US puts \$10 million bounty on Iranian cyber official, military ties of Chinese hacking group QTFY. The post In Other News: InjectEave Attack, SIM Swapper Sentenced, Glasswing Findings Review appeared first on SecurityWeek .

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: <https://www.securityweek.com/in-other-news-injecteave-attack-sim-swapper-sentenced-glasswing-findings-review/>

04. Russian State-Sponsored Hackers Use Claude to Rebuild Malware After Detection

Anthropic on Thursday revealed it disrupted a campaign mounted by a Russian state-sponsored threat actor that abused Claude for developing an AI-assisted workflow to get ahead of the detection curve. The operation has been attributed to a cyber espionage group it calls GTG-20006 (where "GTG" stands for Generative Threat Group), which aligns with broader rep...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://thehackernews.com/2026/09/russian-state-sponsored-hackers-use.html>

05. How Threat Actors Are Turning Trusted AI Platforms Into an Attack Surface

Threat actors are abusing trusted AI platforms to host malicious content, poison search results, and trick users into installing malware. Huntress examines campaigns targeting AI users through weaponized Claude Artifacts, shared AI conversations, sponsored search results, and ClickFix-style lures. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.bleepingcomputer.com/news/security/how-threat-actors-are-turning-trusted-ai-platforms-into-an-attack-surface/>

06. Hackers Favor US Eastern Business Hours in M365 Phishing Campaign

KnowBe4 researchers observed a new phishing campaign leveraging Microsoft 365's Direct Send to send malicious emails

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: <https://www.infosecurity-magazine.com/news/hackers-us-business-hours-m365/>

07. Trezor Says 347,000 Users Received Phishing Emails After Brevo Hack

Hackers compromised the Brevo marketing platform and used that access to send phishing emails to users of Trezor, BitBox, and CoinTracking. The post Trezor Says 347,000 Users Received Phishing Emails After Brevo Hack appeared first on SecurityWeek .

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources:

<https://www.securityweek.com/trezor-says-347000-users-received-phishing-emails-after-brevo-hack/>

08. Ukrainian lawyer's second career as a Conti coder earns him 4 years behind bars

Swapping legal work for malware development ended in extradition and a guilty plea

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.theregister.com/cyber-crime/2026/09/11/ukrainian-lawyers-second-career-as-a-con-ti-coder-earns-him-4-years-behind-bars/5295841>

09. Android malware creates a hidden copy of your banking app

The Gigabud banking Trojan can clone a banking app into a separate work profile on an Android device to help hide fraudulent transactions.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.malwarebytes.com/blog/mobile/2026/09/android-malware-creates-a-hidden-copy-of-your-banking-app>

10. [+24h Old] Attackers use passkey-themed scams to hijack Microsoft 365 accounts

Attackers are using passkey-themed social engineering to trick employees into giving them access to their Microsoft accounts. Microsoft Security Research said it has been tracking active cloud intrusions since May in which attackers impersonated IT helpdesk staff, told employees they needed to update or enroll a passkey , and then took them to adversary-in-...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: <https://www.csoonline.com/article/4221110/attackers-use-passkey-themed-scams-to-hijack-microsoft-365-accounts.html>

Latest Vulnerabilities (10)

01. Why AI raises the stakes for exposure validation

AI dominated the conversation at Fal.Con 2026, but one of the most important takeaways wasn't simply how AI is changing cyber defense. It was how AI is changing the speed and scale of a problem defenders already face. Security teams already have more vulnerabilities and security signals than they can reasonably act on. As AI makes it faster to discover vuln...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources:

<https://www.csoonline.com/article/4221299/why-ai-raises-the-stakes-for-exposure-validation.html>

02. Max severity GitLab path traversal flaw under active reconnaissance

The flaw could enable sensitive files to be read with just an HTTP request.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources:

<https://www.scworld.com/news/max-severity-gitlab-path-traversal-flaw-under-active-reconnaissance>

03. VU#369611: ExLlamaV3 contains Denial of Service vulnerability via insufficient bounds checking on kernel dispatch index

Overview An out-of-bounds (OOB) memory access vulnerability involving unchecked array indexing has been identified in the exllamav3_ext compute unified device architecture (CUDA) extension. Successful exploitation can lead to an immediate denial of service or application instability. This vulnerability is tracked as CVE-2026-84286. Description An OOB memo...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://kb.cert.org/vuls/id/369611>

04. Check Point patches two critical VPN gateway bugs

Check Point fixed two 9.8-severity VPN flaws before any known exploitation in the wild.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.scworld.com/news/check-point-patches-two-critical-vpn-gateway-bugs>

05. CISA Calls for More Guidance, Less Spin, as Cyber Outages Escalate

A new joint government advisory signals a regulatory shift, pressing organizations to adopt more transparent breach notification and incident response protocols.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.darkreading.com/cyber-risk/cisa-calls-for-more-guidance-less-spin-as-cyber-outage-s-escalate>

06. More JFrog Artifactory bugs under attack, and all 3 have patches

If you're waiting for a sign to upgrade to a fixed version: this is it

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.theregister.com/security/2026/09/11/more-jfrog-artifactory-bugs-under-attack-and-all-3-have-patches/5295943>

07. GitLab CVSS 10 File-Read Flaw Draws In-the-Wild Probes After Disclosure

GitLab has released patches to address multiple flaws, including a maximum-severity security vulnerability that has witnessed in-the-wild probes within hours of public disclosure. The vulnerability in question is CVE-2026-85706 (CVSS score: 10.0), a path traversal issue in the repository commits API that could allow an unauthenticated user to read arbitrary...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://thehackernews.com/2026/09/gitlab-cvss-10-file-read-flaw-draws-in.html>

08. ConnectWise patches critical ScreenConnect authentication failure after five days

ConnectWise has issued a security update for ScreenConnect, five days after warning customers the product could allow files to be transferred and executed through active remote sessions without authorization or confirmation. The company warned customers on Sept. 3 of the problem with support and access sessions in ConnectWise Remote Access, advising admins...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.csoonline.com/article/4221263/connectwise-patches-critical-screenconnect-authentication-failure-after-five-days-2.html>

09. GitLab Vulnerability Exploited One Day After Disclosure

The critical-severity path traversal flaw allows unauthenticated attackers to read arbitrary files from the GitLab server. The post GitLab Vulnerability Exploited One Day After Disclosure appeared first on SecurityWeek .

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.securityweek.com/gitlab-vulnerability-exploited-one-day-after-disclosure/>

10. India's STPI serves TerminalFix-style attack via fake Cloudflare check

A website linked to India's Software Technology Parks of India (STPI) is serving a spoofed Cloudflare verification page that silently copies a malicious string to visitors' clipboards and prompts them to execute it via Windows Terminal, in a technique consistent with emerging TerminalFix-style attacks. STPI, a Government of India organization that supports...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.csoononline.com/article/4221243/indias-stpi-serves-terminalfix-style-attack-via-fake-cloudflare-check.html>

Data Breach & Cybercrime (10)

01. Threat Actor Generates 1M Personalized Fraud Emails in 3 Days

Cybercriminals behind malicious email campaigns no longer have to compromise volume for credibility, or vice versa, thanks to AI.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources:

<https://www.darkreading.com/cyberattacks-data-breaches/1m-personalized-fraud-emails-3-days>

02. Florida confirms DMV database breached via stolen police account

The Florida Department of Highway Safety and Motor Vehicles (FLHSMV) has confirmed that its DAVID driver database suffered a data breach, saying the attackers gained access using credentials belonging to a police department employee. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/security/florida-confirms-dmv-database-breached-via-stolen-police-account/>

03. Why AI Is So Good at Scamming Humans

Fred Heiding of Menlo Park Intelligence talks with the Dark Reading News Desk about his research on frontier models, and their ability to influence human behavior and create emotional dependency.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.darkreading.com/cyber-risk/ai-scamming-humans>

04. Passkey-themed phishing attacks lead to Microsoft 365 data theft

Microsoft says threat actors linked to ShinyHunters, Helix, and other extortion gangs are using passkey and single sign-on-themed social engineering attacks to compromise corporate Microsoft accounts and steal data from Microsoft 365 services. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/security/passkey-themed-phishing-attacks-lead-to-microsoft-365-data-theft/>

05. Phishing Research Challenges Conventional Security Awareness Testing

Analysis of 2.47 million simulated attacks shows why organizations should measure credential leaks and reporting, not just clicks. The post Phishing Research Challenges Conventional Security Awareness Testing appeared first on SecurityWeek .

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources:

<https://www.securityweek.com/phishing-research-challenges-conventional-security-awareness-testing/>

06. Papercut AI Swarm Attack Heralds Changes for Cyber Kill Chain

From creating lab environments for staging and testing agentic attacks to reconnaissance to lateral movement and exfiltration, the most innovative attackers are widely incorporating AI.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources:

<https://www.darkreading.com/cyberattacks-data-breaches/papercut-ai-swarm-attack-cyber-kill-chain>

07. Crypto customers targeted by scammers after email marketing provider breach

A breach at email marketing company Brevo exposed Trezor, CoinTracking, and BitBox customers to phishing emails, but others may also be at risk.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.malwarebytes.com/blog/news/2026/09/crypto-customers-targeted-by-scammers-after-email-marketing-provider-breach>

08. The Self-Expanding Stolen Inference Supply Chain: An AI Agent Harvesting and Re-Serving LLM Access, (Fri, Sep 11th)

I identified an attacker using a semi-autonomous coding agent to run an offensive operation: finding poorly secured LLM resale gateways, acquiring API access through ordinary web flaws and account farming, validating the resulting inference capacity, and aggregating it behind a single gateway of their own.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://isc.sans.edu/diary/rss/33332>

09. Ukrainian Conti Ransomware Developer Sentenced to 4 Years in US Prison

Oleksii Oleksiyovych Lytvynenko has been sentenced to 4 years in prison after he was arrested in Ireland in 2023. The post Ukrainian Conti Ransomware Developer Sentenced to 4 Years in US Prison appeared first on SecurityWeek .

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://www.securityweek.com/ukrainian-conti-ransomware-developer-sentenced-to-4-years-in-us-prison/>

10. [+24h Old] IDScan confirms breach after 153 million driver's licenses leak on dark web

Days after reports linked IDScan to a dark web database holding more than 153 million driver's license scans, the identity verification company has confirmed hackers accessed customer data stored on its cloud platform. The Louisiana-based firm, which processes ID checks for car rental companies, retailers and cannabis dispensaries, posted a notice on its we...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources:

<https://www.helpnetsecurity.com/2026/09/11/idscan-net-data-breach-153-million-drivers-licenses/>